

GRC102: INFORMATION SECURITY GOVERNANCE

ASSIGNMENT 1

Principles of Information Security Governance

Full Name	MERCY RACHAEL AJAYI
Registration Number	C11/26/CGRCE/17219
Cohort / Batch	CGRCE Cohort 11
Course Title	Information Security Governance
Date Submitted	10th September, 2026

PART 1 - GOVERNANCE STRUCTURE ANALYSIS

1. TechCorp's Current Governance Weaknesses

TechCorp's current approach has several weaknesses, which show that its information security governance has not kept pace with the business. The main concern is that information security is still treated mainly as an IT responsibility instead of a business-wide responsibility that requires clear direction, risk oversight, and accountability (ISACA, 2019b). Since most security decisions are handled by one technical role, there is no independent structure to assess whether the risks being accepted are within the organisation's risk appetite and support its plans for growth. This becomes more important as TechCorp expands. An informal approach that may work for a single-country company with about 500 employees may not be sufficient when the organisation has to deal with different regulators, legal requirements, and customer expectations. The five weaknesses below are connected, so addressing only one would not resolve the wider governance gaps.

Assumption:

TechCorp's international expansion is treated as entry into new regulatory jurisdictions with their own data-protection and cybersecurity requirements, rather than simply opening offices under the existing legal framework. This is reasonable because the scenario focuses on governance maturity before expansion, and entering new jurisdictions would create additional obligations.

Weakness	Governance Issue	Potential Business Impact	Effect on Planned International Expansion
Security decisions are mainly made by the IT Director	Security decision-making is too concentrated in one IT role, with limited involvement from other business, risk and compliance functions. The same person responsible for managing IT is also involved in deciding how much security risk the organisation should accept, which can create a conflict of interest and make accountability unclear because there is no clear separation between overseeing security and managing IT operations.	Security risks tend to be looked at from the technical side, without enough attention to the business, legal, financial or operational effects. Security spending may also follow IT priorities and budget rather than the actual risks facing the organisation, especially with no independent person to challenge these decisions.	International expansion will bring new legal, privacy and operational requirements that cannot be handled by IT alone. Without a clear person responsible for security, it is difficult to know who answers for meeting each country's data protection and cybersecurity requirements.
The Board receives only one security update each year	Board oversight is limited because getting security updates only once a year does not give the board a clear picture of the organisation's changing cyber risks. This can make it difficult for the board to properly guide security decisions and hold management accountable.	The Board may not have enough information to question management or make informed decisions on major cyber risks, so important risks may not reach the board early enough for action to be taken.	Expansion increases exposure to cyber risk, which makes regular Board oversight more important. Without enough information, the Board cannot properly assess the risks of entering new markets.
Security policies are outdated	The company's policies have not kept up with changes in technology, risk and business growth, and there is no clear	Employees may follow requirements that no longer match the company's current risks or how work is actually	Existing policies may not cover the privacy, data protection and security requirements of other countries, leaving the

	process for reviewing and updating them or checking that they are followed	done, leading to inconsistent practices, more human error and less reliable controls.	company unprepared to meet local rules and creating compliance issues.
No formal security committee or governance body	There is no structured forum where security risks and priorities are discussed with input from different areas of the business, so decisions may be made informally without clear records of who agreed to them.	Security issues may remain within IT without getting the wider attention or resources they need. This can also lead to different departments making their own risk decisions without clear documentation or shared ownership of security policies and initiatives.	Expansion involves more stakeholders, systems and countries, making coordination harder. Without a formal forum, issues such as data localisation and cross-border transfers may be delayed or overlooked.
Security Incidents are handled reactively with no formal escalation process	There is no clear process for managing incidents, who should respond, when to escalate and who to inform, making it hard to respond well, learn from incidents and fix their causes.	A slow or poorly coordinated response increases the financial, operational and reputational damage of an incident, and inconsistent handling means the company may not learn from past events.	Cross-border incidents involve different reporting, legal and communication requirements. Without a formal process, TechCorp may miss important reporting deadlines and face additional compliance or reputational issues.

2. Proposed Information Security Governance Structure for TechCorp

I would put in place a structure that keeps security connected to IT delivery while maintaining enough independence for oversight and risk decisions. The structure would follow the three-lines model. Business and system owners would be responsible for risks within their areas as the first line. The CISO and security function would set standards, monitor compliance, and provide challenge as the second line. Internal audit would provide independent assurance as

the third line and report to the Board Risk/Audit Committee (ISACA, 2019b). The structure should clearly show four things: who owns security risk, who has decision-making authority, who provides oversight, and how serious issues are escalated when they cannot be resolved within the relevant line.

Proposed governance structure: roles and reporting

Level	Role / Body	Oversight Relationship / Reporting
1	Board of Directors	Provides overall oversight of major information security and business risks and holds executive management accountable for the organisation's security posture.
2	Board Risk/Audit Committee	Reviews security and risk reports on behalf of the Board, challenges management's assumptions, and escalates major concerns to the full Board when necessary.
3	CEO / Executive Management	Makes major business and risk decisions, provides the resources needed for security, and remains accountable to the Board for how security risks are managed.
4	CISO	Leads the security programme, advises executive management, and reports to the CEO (not the IT Director).
4	Information Security Governance Committee	Brings together Security, IT, Risk, Legal/Compliance, HR, Finance, and business representatives to review and prioritise security risks across the organisation.
5	Security Team	Handles day-to-day security activities, including monitoring, vulnerability management, and incident response.
5	Business/System Owners	Manage the risks and controls within their areas and are responsible for addressing issues identified in their systems.

The CISO should report to the CEO, not to the IT Director. This reporting line directly addresses TechCorp's main governance weakness because it separates security oversight from IT operations. It also removes the conflict where one person is responsible for running IT while also deciding how much security risk the organisation should accept. The IT Director should remain a standing member of the Information Security Governance Committee and continue

implementing agreed technical controls, but should no longer set the organisation's risk appetite or approve residual security risk.

The Committee is where security decisions move beyond being treated as IT matters. Legal, Finance, HR, and relevant business areas should have standing representation so that regulatory, contractual, financial, and operational concerns are considered before decisions are made, particularly when TechCorp enters a new market.

Decision-making, escalation and Board reporting

Routine issues should remain with the responsible team, while higher-risk matters should involve the CISO and the relevant business owner. Incidents or risks that exceed the organisation's stated risk appetite should be escalated to executive management and, where necessary, the Board Risk/Audit Committee. These escalation thresholds should be agreed in advance so that there is a clear process to follow during a crisis. A practical starting point would be for operational incidents to remain with the Security Team; incidents involving customer, legal, or service impact to be reported to the CISO within one hour; and material data loss, ransomware, or events that could require regulatory or new-market notification to be reported to the CEO and Committee immediately, with the Board Committee informed the same day.

Board involvement should also go beyond the current once-a-year update. Quarterly reporting, alongside immediate reporting of major incidents, would give directors a more current view of key risks, critical vulnerabilities, incident trends, compliance issues, and whether existing controls remain effective. This would allow the Board to ask informed questions and challenge management before major expansion decisions are finalised, rather than only after a security failure. The quarterly report should be brief but useful, covering the main risks against appetite, overdue critical patches, material incidents, open audit findings, and risk acceptances outside appetite. A long technical appendix should not replace this clear management view.

3. Alignment with Core Governance Principles

The proposed structure is based on four core principles of effective information security governance covered in this course and reflected in COBIT's separation of governance from management (ISACA, 2019b).

- **Accountability:** Each role has a clear responsibility. The CISO leads the security programme, business owners manage risks in their areas, executives make major decisions, Internal Audit provides independent assurance, and the Board provides oversight. This prevents one person from making and overseeing the same decision, which is a weakness in the current IT Director model.
- **Strategic alignment:** Security is connected to TechCorp's business objectives, including international expansion, rather than being treated as an IT workstream. Having Legal, Finance, and business representatives on the Committee also ensures these

considerations are included in security decisions.

- **Risk-based decision-making:** Security effort and spending should reflect the level and potential impact of risk, including the additional exposure created by entering new jurisdictions. With limited resources, priority should be given to the risks that could cause the greatest harm.
- **Oversight and transparency:** Regular monthly Committee reviews and quarterly Board reporting replace the current annual update. This gives directors the opportunity to challenge management when controls are not working, rather than finding out after market entry has already started.

PART 2 – FRAMEWORK COMPARISON AND SELECTION

4. Detailed Comparison of COBIT and ISO/IEC 27001

Aspect	COBIT (ISACA, 2019a, 2019b)	ISO/IEC 27001 (ISO, 2022)
Scope and primary focus	It focuses on the governance and management of enterprise information and technology, with emphasis on business goals, risk and value.	It focuses specifically on information security through an Information Security Management System (ISMS) that protects information.
Structure and major components	It uses six governance principles, seven components and 40 governance and management objectives across five main domains.	It uses clauses 4–10 for ISMS requirements and Annex A with 93 controls covering organisational, people, physical and technological areas.
Governance approach	It has a strong governance focus and separates governance from management, helping organisations set direction and monitor IT.	It focuses more on managing information security through a continuous cycle of planning, implementation, checking and improvement.
Implementation and certification	It is not designed for certification and is mainly used as guidance for improving IT governance and maturity.	It can be certified through an external audit, which can provide recognised evidence of an organisation's security practices.
Control selection and risk management	It provides objectives and practices but no fixed control list, allowing organisations to design controls around their needs.	It requires a formal risk assessment and Statement of Applicability to explain which Annex A controls apply and why.

Strengths	It is strong in governance, risk, business alignment and linking IT decisions to organisational goals.	It provides a recognised and certifiable approach to managing information security and demonstrating security and compliance efforts.
Limitations	Its broad approach can make it difficult to apply, especially for smaller organisations, and it does not provide detailed technical controls.	It focuses more on information security than wider IT governance, and certification requires ongoing external audits.
Regulatory alignment (including HIPAA)	It can support governance and alignment with different frameworks, but does not directly map to HIPAA Security Rule controls.	It has similarities with the HIPAA Security Rule because both use risk and control-based approaches, although ISO/IEC 27001 certification is not the same as HIPAA compliance.
Resource requirements	It can require significant time and senior involvement because it covers governance across the organisation.	It requires resources to implement, document and maintain the ISMS, as well as ongoing external surveillance audits.

5. Recommended Framework for MedSecure

For MedSecure, I would use ISO/IEC 27001 as the main operational security framework, supported by selected COBIT governance practices at Board and executive level (ISO, 2022; ISACA, 2019b). This combination gives MedSecure a structured and auditable approach to managing security while keeping security decisions connected to business objectives and Board oversight. I would not run the two as separate programmes.

Healthcare-sector requirements

Patient data is highly sensitive and subject to strict regulation, so MedSecure needs a framework that supports clear and auditable security practices. ISO/IEC 27001 is suitable because its risk assessment process and Annex A controls can be mapped to specific safeguards, while certification can provide independent evidence of the organisation's security posture to regulators, insurers, and partners (ISO, 2022). This is particularly useful in healthcare, where customers and business partners may require more evidence than a set of security policies.

MedSecure's size and complexity

With about 2,000 staff across three states, MedSecure is large enough to require a structured security programme, but implementing COBIT across the whole organisation would be relatively heavy at this stage. ISO/IEC 27001 is therefore a more practical operational foundation. COBIT can be applied where it adds the most value, particularly through Evaluate, Direct and Monitor (EDM) practices, Board reporting, and the separation of governance from management (ISACA, 2019a).

Ability to support HIPAA compliance

ISO/IEC 27001 can support MedSecure's HIPAA compliance efforts because it requires formal risk assessment and documentation of selected controls in the Statement of Applicability. However, certification alone does not mean that MedSecure is HIPAA compliant. The organisation would still need to map its ISMS controls to the HIPAA Security Rule's administrative, physical, and technical safeguards (HHS, n.d.). The SoA provides a practical place to document this mapping, allowing the same controls to support both the ISMS and HIPAA evidence.

Assumption:

MedSecure's three states of operation are treated as U.S. states, making HIPAA the primary regulatory obligation in this scenario. This follows the brief, which identifies HIPAA-related compliance as part of the organisation's responsibility.

Why COBIT as well, and the implementation challenge

ISO/IEC 27001 on its own may not fully connect day-to-day security activities with Board-level governance. COBIT helps address this by linking technology decisions with business objectives, risk, and oversight (ISACA, 2019b). The main implementation risk is duplication, such as having separate owners, risk registers, and reporting processes. MedSecure should therefore manage both frameworks as one programme. The ISMS should provide the operational evidence, while COBIT-style EDM practices and reporting should use that evidence to support executive and Board decisions. Running them separately could turn the ISMS into a security-team paperwork exercise while leaving the Board with general assurance and little visibility into how ISO 27001 findings affect business decisions.

Long-term sustainability and organisational evolution

The same approach can continue to work as MedSecure adds services such as telehealth or develops new data-sharing arrangements with partner organisations. The ISMS scope can expand as new systems and data flows are introduced, while COBIT provides the governance needed as technology and operational complexity increase. Building the framework this way from the start reduces the need for a costly redesign later, when new services may already have been added to a framework designed only for the organisation's original structure.

6. High-Level Implementation Roadmap

I would build the programme around the ISO/IEC 27001 ISMS as the operational core, with COBIT supporting the governance side. An 18-month timeline to certification, followed by continuous improvement, would give MedSecure enough time to implement the framework properly instead of rushing to meet an audit deadline.

Phase	Window	Key Activities
1. Establish governance and scope	Months 0–3	Get executive support, set up a steering committee with the CIO, CISO and clinical/business representatives, define the ISMS scope, assign responsibilities and agree on the budget.
2. Risk assessment and gap analysis	Months 3–9	Carry out the risk assessment, identify gaps against ISO/IEC 27001 Annex A and HIPAA safeguards, and document the selected controls in the Statement of Applicability.
3. Design and implement controls and documentation	Months 9–15	Develop the required security policies and implement priority controls such as access management, monitoring, incident response, vendor management and staff training.
4. Internal audit, corrective action and certification	Months 15–18	Conduct an internal audit, fix identified issues and complete the Stage 1 and Stage 2 certification audits with an accredited body.
5. Operate and continuously improve	After Month 18	Continue the COBIT governance process, provide quarterly reports to the Board, review risk regularly and improve the ISMS as the organisation changes.

Critical Success Factors

- **Executive support:** Senior management needs to treat security as an organisational priority rather than just an IT or compliance task.
- **Clear ownership:** The CISO or another named programme lead should be responsible for the programme and its progress.
- **Risk-based approach:** Controls should be selected based on MedSecure's actual risks rather than simply copying a template.

- **Useful documentation:** Policies and procedures should reflect how MedSecure actually works and be suitable for an audit.
- **Staff involvement:** Clinical and business staff should be involved because their actions also affect healthcare security.

Likely Challenges and Mitigations

Challenge	Mitigation
Limited security and compliance capacity	Use external support for the gap analysis and audits while training internal staff.
Busy clinicians seeing security as an obstacle	Explain how security helps protect patients and keep services available, while involving clinical staff from the beginning.
Scope creep across three states	Start with a clear and manageable scope before expanding it gradually.
Cost and disruption of certification	Include certification costs in the budget and spread the work across the 18-month period.
Losing focus on governance	Keep the COBIT-based Board reporting on a regular quarterly schedule.

Resources and Timeline

The programme would require a programme lead and coordinator, external support for the initial risk assessment and gap analysis, time from the internal security, IT, and compliance teams, an accredited certification body, and funding to address any identified gaps. An 18-month timeline is realistic for MedSecure because it allows enough time to prepare properly for certification while maintaining regular governance and reporting. Shortening the timeline just to reduce costs could weaken the programme, as a rushed ISMS may result in documentation that does not reflect how the organisation actually operates. This could lead to more findings during the certification audit.

PART 3 – CASE STUDY ANALYSIS: EQUIFAX DATA BREACH

7. Governance Failures in the Equifax Breach

The Equifax breach shows why information security governance must be connected to day-to-day security work. The issue was not simply that a vulnerability existed, but that there was no reliable process for confirming that a required patch had been applied or escalating the issue when it had not. The Federal Trade Commission reported that Equifax was notified of a critical Apache Struts vulnerability in March 2017 and instructed its security team to patch

affected systems within 48 hours. However, there was no effective follow-up, allowing the vulnerability to remain exploitable for months (Federal Trade Commission [FTC], 2019). Congressional investigations identified similar weaknesses, including unclear security accountability, limited Board oversight, and controls that existed on paper but were not properly checked in practice (House Committee on Oversight and Government Reform, 2018; Senate Permanent Subcommittee on Investigations, 2019). Expired SSL certificates also prevented monitoring tools from properly inspecting encrypted traffic, making the situation worse. These gaps in ownership, follow-up and assurance ultimately allowed a known vulnerability to become a major breach affecting about 147 million people.

Governance issue	How it contributed to the breach or increased its impact	Governance principle not adequately applied
Unclear security accountability and leadership.	Security responsibilities were divided between the CIO and CSO without one clear person being responsible for the overall security outcome. This made it easier for important tasks such as patching and monitoring to be missed because responsibility was not clearly owned.	Clear accountability and separation of duties: Security responsibilities and outcomes should be clearly assigned.
Inadequate vulnerability and patch-management governance.	A critical vulnerability was identified in March 2017, but the instruction to patch the affected systems within 48 hours was not properly followed up. The vulnerability remained open for months and gave attackers a way into the system. No one verified that the required patch had actually been applied.	Management commitment and policy enforcement: security requirements should be followed up and verified to make sure they are actually implemented.
Poor network segmentation and intrusion detection	Attackers were able to move through the systems and remain undetected for months. Weak segmentation and monitoring made it harder to detect and contain the attack early, allowing more data to be stolen.	Risk management and continuous monitoring: security controls need to be properly implemented and regularly monitored.
Slow and poorly governed disclosure.	There was a significant delay between discovering the breach	Incident-response and stakeholder-communication

	and informing the public, along with problems in the early communication. The delay increased the reputational damage and affected public trust in the company.	governance: there should be a clear and timely process for communicating major security incidents.
Security policies and controls were not properly enforced.	Equifax had security requirements in place, but there was not enough checking to confirm that they were being followed. As a result, some basic security protections were not actually in place when they were needed.	Oversight and independent assurance: organisations should regularly check that their security controls are implemented and working as expected.

8. What I would have established as CISO before the breach

If I had been Equifax's CISO before the breach, my priority would have been to establish clear ownership, independent oversight, and a process that ensures identified risks are properly addressed and verified. The main weakness was not the lack of policies, but the lack of follow-up. The structures below are therefore focused on closing that gap rather than creating more documents.

- **Governance bodies and responsibilities:** An Information Security Governance Committee would include Security, IT, Risk, Legal/Compliance, Privacy and relevant business units. The CISO would be responsible for security strategy, risk reporting, policy and incident governance, and would report directly to the CEO rather than only through the CIO.
- **Risk management:** A live risk register would record each risk, affected asset, owner, severity, treatment, deadline and current status. Any major risk that was not addressed within the agreed timeframe would require formal acceptance by an authorised senior person instead of being left open without action.
- **Accountability mechanisms:** Every critical system, data store and key control would have a named owner.
- **Board reporting and oversight:** The Board or its risk committee would receive regular reports covering material risks, incidents, critical vulnerabilities, overdue remediation, audit findings and high-risk exceptions. This would give the Board enough information to question management and monitor progress rather than receiving only an annual summary.

- **Vulnerability-management governance:** There would be a formal process for identifying, rating, assigning, setting deadlines, verifying and escalating vulnerabilities. Internet-facing critical vulnerabilities would have short remediation deadlines, with automatic escalation when these were missed. Being “instructed to patch” would not be treated as evidence that the patch had actually been applied.
- **Policy enforcement:** Completion would be confirmed and then independently verified. If a critical patch was required within 48 hours, the system owner would confirm that it had been applied, while Security would verify the result. This is the control that was missing in the Apache Struts case.
- **Security architecture and monitoring:** Internet-facing systems would have clear requirements for segmentation and access restrictions. Systems containing sensitive personal data would also require effective monitoring of encrypted traffic, with expired certificates treated as a security control failure rather than simply an IT maintenance issue.
- **Policy review and independent assurance:** Critical policies would be reviewed on a defined cycle. Internal Audit would test patching, monitoring and certificate management and report any weaknesses to both management and the Board.

9. Wider Governance Lessons from the Equifax Incident

The first lesson is that regulatory expectations for security governance have become stronger since 2017. The FTC settlement required an ongoing information security programme, regular risk assessments, documented safeguards, independent testing and monitoring, as well as Board or committee-level oversight (FTC, 2019). This shows that regulators now want evidence that security processes are actually working, not simply a folder containing policies.

The second lesson is the increased role of the Board in security oversight. Before the breach, Equifax’s Board had limited visibility into its actual security risks (House Committee on Oversight and Government Reform, 2018). The expectation now is for regular and meaningful reporting on cyber risk. Directors do not need to understand every technical detail, but they should have enough information to ask relevant questions and challenge management when critical patches are overdue or monitoring controls have failed.

The third lesson is executive accountability. The resignation of Equifax’s Chief Security Officer and Chief Information Officer after the breach showed that responsibility for this type of failure does not rest only with the engineer who failed to apply a patch. When the underlying problem involves weak oversight and poor follow-through, accountability must also extend to the executives responsible for security governance.

The fourth lesson is especially relevant to organisations that hold large amounts of personal, financial or health data, including firms such as MedSecure and GlobalFinance in this assignment. Having capable security staff is not enough if there is no process for taking known

risks through to completion. Critical vulnerabilities need clear owners, deadlines, escalation and verification. Security also needs to be treated as part of enterprise risk rather than as an issue that sits only within IT. Equifax shows how several smaller weaknesses in governance and follow-through can combine to create a major incident.

PART 4 – GOVERNANCE PRINCIPLES APPLICATION

10. Information Security Governance Principles for GlobalFinance

Because GlobalFinance operates across 20 countries and gives its regional offices significant autonomy, its security principles need to create a common direction without assuming that every region can follow exactly the same processes. The aim is to establish a mandatory minimum level of security that protects the group, while still allowing each region to meet stricter local regulatory requirements or respond to its own market structure. This is particularly important in financial services because a weakness in one country, such as in cross-border payments, correspondent banking or a locally licensed entity, can create wider conduct, prudential or data-protection risks for the group. I would therefore establish the eight principles below.

Assumption: *The 20 countries are treated as having their own financial-services regulators and data-protection laws, rather than operating under one shared rulebook. This follows the scenario, which presents GlobalFinance as a decentralised organisation where regulatory requirements and market conditions may differ across regions.*

Principle	Importance in a financial-services environment	Application in practice	Likely implementation challenge
Clear accountability	Financial organisations handle sensitive financial and customer information, so unclear responsibility can leave important risks unmanaged.	Every major security risk, critical system and key control should have a named owner, while regional leaders remain responsible for local implementation.	Some regional teams may still see security as the responsibility of the central security team.
Least privilege and controlled access	Financial systems contain sensitive customer, transaction and operational information, making unnecessary access a major risk.	Access should be based on job requirements, reviewed regularly and removed when it is no longer needed.	Employees and operational teams may resist controls they find inconvenient.
Local regulatory compliance	Financial services are subject to different laws and regulatory	Use the global requirements as a minimum and allow	Local requirements may be stricter than the global standard or require

	requirements in each country.	regions to add controls needed to meet local laws or regulatory expectations.	different processes.
Risk-based decision-making	Financial institutions face different cyber and operational risks, while security resources are limited.	Use a common risk assessment method and risk appetite, while allowing authorised risk owners to make decisions within approved limits.	Different regions may assess similar risks differently.
Global minimum security baseline	A multinational financial organisation needs a consistent minimum level of protection across all locations.	Set mandatory requirements for areas such as access control, vulnerability management, incident response and monitoring.	Some regions may have legacy systems that cannot immediately meet the baseline.
Security by design	Security weaknesses introduced during development can become more difficult and expensive to fix later.	Include security and risk reviews in major projects, new products and significant technology changes.	Business teams may see security reviews as something that slows down delivery.
Transparent reporting and escalation	Management needs timely information about incidents and risks that could affect customers, operations or regulatory obligations.	Set clear reporting thresholds and escalation routes for major incidents, overdue risks and serious control failures.	Teams may delay reporting because they are concerned about criticism or scrutiny.
Continuous improvement	Cyber threats, technology and regulatory requirements continue to change, so security governance cannot remain static.	Regularly review incidents, audit findings, emerging threats and regulatory changes, then use the findings to improve the governance programme.	Governance reviews may become routine if management does not use the results to make improvements.

11. Balancing the Competing Needs

The main challenge for GlobalFinance is finding the right balance between central control and regional flexibility. The organisation needs consistent security standards across all its regions, while still giving each region enough flexibility to meet its local requirements.

Competing need	How the principles balance it
Global consistency and local flexibility	GlobalFinance should set mandatory minimum security requirements, common risk terms and reporting expectations. Regions can decide how to meet these requirements and add extra controls where local laws or risks require them.
Security requirements and business agility	Security should be considered early in business and technology decisions and should be based on the level of risk. Higher-risk activities should receive more detailed review, while lower-risk changes can follow a simpler process.
Compliance obligations and innovation	Regulatory requirements should be treated as the minimum that must be met, without stopping responsible innovation. New technology should be assessed for security and compliance risks before use, with compensating controls considered where necessary.
Centralised oversight and distributed responsibility	The central security function should set the overall direction, maintain the global baseline and monitor major risks. Regional and business leaders should remain responsible for implementing controls and managing risks in their own areas.

12. Governance Mechanism for Maintaining Adherence

I would establish a governance and assurance process that allows GlobalFinance to measure adherence across all regions without requiring every region to operate in exactly the same way.

Level/activity	Responsibility	Example measures
Global security baseline	Central CISO / Security Governance Committee	Approved policies, mandatory controls, risk thresholds and reporting requirements.
Regional implementation	Regional leadership and security teams	Control implementation, local regulatory requirements and remediation of identified gaps.
Measurement	Security, Risk and Compliance	Critical vulnerability remediation,

		access review completion, incident response, audit findings and policy compliance.
Reporting	Regional leadership → CISO → Executive Management → Board	Monthly or quarterly risk dashboards, major exceptions and material incidents.
Exception management	Risk owner with appropriate approval authority	Reason for the exception, risk assessment, compensating controls, approval and expiry date.
Independent assurance	Internal Audit / independent assessor	Periodic testing of important controls and governance processes.
Continuous improvement	CISO and Governance Committee	Review of incidents, audit findings, regulatory changes, emerging threats and lessons learned.

Adherence should be measured using a short, common set of indicators: critical vulnerabilities fixed within the required timeframe, completion of access reviews and security training, incident volumes and response times, open audit findings, and the number and age of approved exceptions. Each region would report these same measures, making it possible to compare results and combine them into a group-level view for management and the Board. Keeping the list short should also make consistent reporting more realistic across 20 countries than relying on a large local scorecard.

Responsibility must be clear at every level. The Group CISO would own the overall framework, regional leaders would be responsible for implementing it within their entities, and line managers would ensure the controls are followed within their teams. This makes security a shared responsibility and provides a clear point of accountability when a control is not working or a risk requires a decision. The structure also reflects the three lines used for TechCorp: regions and business owners operate the controls, Group Security sets the minimum requirements and challenges exceptions, while Internal Audit independently tests the controls and exception process. Group Security should not be the only line of defence in a 15,000-person organisation.

If a region cannot meet a requirement, such as a legacy core system that cannot yet support multifactor authentication, it must submit a formal, time-limited exception. The request would explain the reason, the associated risk, any compensating controls, the required approver and the expiry date. High-risk exceptions would be escalated to Group Security leadership and, where necessary, executive management or the Board. Having an expiry date prevents exceptions from becoming permanent gaps in the security baseline.

Finally, the principles should be reviewed at least annually and earlier if there is a material incident, significant regulatory change, or entry into a new market or product line. The review

would consider incidents, audit findings and supervisory feedback across the 20 countries before updating the baseline where the requirements have become too weak or too restrictive. This makes adherence an ongoing governance responsibility rather than a one-time compliance exercise.

References

- Federal Trade Commission. (2019, July 22). Equifax to pay \$575 million as part of settlement with FTC, CFPB, and states related to 2017 data breach. <https://www.ftc.gov/news-events/news/press-releases/2019/07/equifax-pay-575-million-part-settlement-ftc-cfpb-states-related-2017-data-breach>*
- House Committee on Oversight and Government Reform. (2018). The Equifax data breach: Majority staff report (115th Cong.). U.S. Government Publishing Office.*
- International Organization for Standardization. (2022). ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection. Information security management systems - Requirements. ISO.*
- ISACA. (2019a). COBIT 2019 framework: Governance and management objectives. ISACA.*
- ISACA. (2019b). COBIT 2019 framework: Introduction and methodology. ISACA.*
- Senate Permanent Subcommittee on Investigations. (2019). How Equifax neglected cybersecurity and suffered a devastating data breach. U.S. Senate Committee on Homeland Security and Governmental Affairs.*
- U.S. Department of Health and Human Services. (n.d.). Health Insurance Portability and Accountability Act of 1996 (HIPAA). Office for Civil Rights. Retrieved September 9, 2026, from <https://www.hhs.gov/hipaa/index.html>*